Verdict Runtime

BENCHMARK
2026-11-04
10 apps · 5 languages

We find more labelled flaws than GitHub CodeQL

Head-to-head on ten deliberately vulnerable open-source applications, scored against each app's own labels, plus a live layer that *proves* findings.

> On **10 deliberately vulnerable open-source applications across 5 languages**, Verdict Runtime found **92 of 167** labelled, statically findable flaws. **GitHub CodeQL found 68**.

92/167
Flaws found — Verdict Runtime

68
GitHub CodeQL · +24 for us

10
Apps · 5 languages

Round 1: code scanning, like for like

A flaw counts as found only when the correct vulnerability class is reported within ±3 lines of the labelled location, scored against an answer key built from each app's own labels.

SCANNER	LABELLED FLAWS	FOUND	SHARE
Verdict Runtime	167	**92**	**55%**
GitHub CodeQL	167	68	41%

The layer the static scanners don’t have LIVE PROOF

9 additional vulnerabilities confirmed by actually exploiting three of the running apps

Verdict Runtime doesn’t just read code: its agents send real, scope-authorised requests and **prove** each finding against the live application, with a reproducing request each:

- **Broken object authorisation (BOLA/IDOR)** — one account read another account’s private data
- **Authentication-token forgery** — an unsigned (`alg:none`) token accepted as valid
- **Exposed admin / debug surfaces** — internal config and server logs served to an unauthenticated request
- **Missing login rate-limiting & weak session cookies**

Static scanners, CodeQL included, cannot prove any of these. Broken authorisation and token forgery are logic flaws that only show up when you exercise the live application.

The team

Verdict Runtime is built by defenders with more than 15 years in security: protecting applications and infrastructure, running vulnerability programmes at enterprise scale, and building security products that teams rely on. We have a proven record of finding real risk and getting it fixed, and we built the tool we wished we had.

15+
years in security, across defense, vulnerability management and product

Defense
securing applications and infrastructure in production, so every fix and defense rule is built to be deployed

Scale
enterprise vulnerability management: triage, prioritisation and remediation across large estates

Product
security products designed, shipped and run in production

Method & scope. Ten deliberately vulnerable open-source training applications in five languages (JavaScript/TypeScript, Python, Java, Go, C#), each scored against an answer key built from the app’s own labels; a detection counts only when the correct vulnerability class is reported within ±3 lines. CodeQL ran its security-extended suites; Verdict Runtime ran its standard code, secrets and infrastructure-as-code scan (2026-11-04). The live-proof results come from Verdict Runtime’s agents against disposable, explicitly authorised local instances. These are labelled training targets, so the results show a measured lead on this suite, not a claim of universal superiority. CodeQL is a trademark of GitHub, Inc.